Universidad Nacional de Costa Rica · Escuela de Informática

Administración de Bases de Datos · II Ciclo 2026

Controles ISO/IEC 27001:2022 para la confidencialidad en la administración de bases de datos Oracle

Profesor: Johnny Villalobos Murillo

Estudiante: Ismael Rojas Herrera

28/10/2026

> Este artefacto NO está conectado a Oracle. Presenta información y evidencias registradas al ejecutar los scripts del repositorio. Los datos del laboratorio son ficticios. No constituye una certificación ISO. El artefacto interactivo está en `artefacto/index.html` (abrir con doble clic) y contiene las salidas completas de cada evidencia.

1. Resumen

Se diseñó y verificó un marco de controles basado en el Anexo A de ISO/IEC 27001:2022 para la confidencialidad en las tareas del DBA, sobre Oracle AI Database 26ai Free, Release 23.26.1.0.0 (contenedor Docker oficial, PDB FREEPDB1). Se identificaron 6 riesgos y 15 tareas críticas, se mapearon 15 controles y se construyeron 15 comprobaciones observables y 19 pruebas. Resultado registrado: 13 comprobaciones en CUMPLE, 2 en PARCIAL y 0 en NO CUMPLE; 19 de 19 pruebas con el resultado esperado; madurez promedio 2.7 de 4. Las brechas se explican en la sección «Actuar».

2. Alcance, entorno y metodología

Motor	Oracle AI Database 26ai Free, Release 23.26.1.0.0 (contenedor Docker oficial, PDB FREEPDB1)
Auditoría	Unificada pura (`UNIFIED_AUDIT_TRAIL`; `audit_trail = NONE`), por lo que `SYS.AUD$` no aplica
Opciones verificadas	V$OPTION: TDE, Backup Encryption, Data Redaction, FGAC (VPD), FGA, Privilege Analysis y Unified Auditing = TRUE; Database Vault y Label Security = FALSE
Red	Puerto 1521 del contenedor publicado solo en 127.0.0.1:1522; cifrado nativo AES256/SHA256 obligatorio
Herramientas	SQL*Plus, RMAN y Data Pump dentro del contenedor; SQL Developer para las capturas; Git Bash para los scripts

Fase	Qué se hizo	Scripts
Planificar	Diagnóstico del entorno, escala de riesgo, riesgos, tareas, selección y mapeo de controles	`sql/00_diagnostico`, este informe
Hacer	Keystore TDE, tablespace cifrado, esquema ficticio, usuarios/roles/perfiles, clasificación, VPD, Redaction, auditoría, retención, copia DEV enmascarada, RMAN cifrado, cifrado de red	`sql/10_lab_setup`, `herramientas/aplicar_cifrado_red.sh`
Verificar	19 pruebas positivas y negativas; 15 comprobaciones observables con resultado calculado	`sql/30_pruebas`, `sql/20_verificacion`
Actuar	Corrección de hallazgos (A-01, A-02), re-verificación, riesgo residual y propuestas	`sql/40_actuar`

3. Riesgos

Nivel = P × I. Bajo 1–4 · Medio 5–9 · Alto 10–15 · Crítico 16–25. Riesgo inherente: sin controles. Riesgo residual: con los controles aplicados y verificados en el laboratorio.

Valor	Probabilidad (P)	Impacto (I)
1	Raro: requiere varias fallas simultáneas	Dato público o sin valor
2	Improbable: requiere acceso interno y conocimiento especial	Dato interno sin datos personales
3	Posible: la configuración por defecto lo permite si no se corrige	Datos personales de pocos registros
4	Probable: error común de administración o práctica habitual	Datos personales masivos (Ley 8968)
5	Casi seguro: ocurre sin controles en uso normal	Datos sensibles o financieros masivos, con obligación de notificar

ID	Activo	Amenaza / vulnerabilidad	Escenario	P	I	Inherente	Justificación	Controles	Residual (tras verificar)
R-CONF-01	Tabla CLIENTES (datos personales)	**Amenaza:** Abuso de privilegios **Vulnerabilidad:** Roles amplios, privilegios ANY o grants a PUBLIC	Una cuenta de aplicación con SELECT ANY TABLE extrae todos los clientes	4	5	20 Crítico	Conceder roles amplios «para que funcione» es un error frecuente de administración y afecta a todos los registros	A.5.15, A.5.18, A.8.2, A.8.3	2×5 = 10 Alto VPD deniega por defecto, Redaction oculta la tarjeta, VC-07 detecta privilegios ANY y A-01 los corrigió. Persiste el riesgo del DBA (PR-19).
R-CONF-02	Cuentas y credenciales	**Amenaza:** Suplantación de identidad **Vulnerabilidad:** Contraseñas débiles o compartidas, sin bloqueo ni cierre de sesiones inactivas	Se adivina la contraseña de JUAN (igual al usuario, como en la pizarra) o se usa una sesión desatendida	4	4	16 Crítico	El perfil DEFAULT no tiene función de verificación ni IDLE_TIME (E-00)	A.5.16, A.5.17, A.8.5	2×4 = 8 Medio El perfil confidencial rechaza contraseñas débiles (PR-11), bloquea tras 3 intentos (PR-12) y cierra sesiones inactivas (PR-13). El perfil DEFAULT sigue sin endurecer (VC-04 = PARCIAL).
R-CONF-03	Datafiles, respaldos y exports	**Amenaza:** Copia no autorizada **Vulnerabilidad:** Archivos sin cifrar	Se copia un datafile o un archivo .dmp y se lee fuera de la base	3	5	15 Alto	Requiere acceso al servidor o a los medios, pero evita todos los permisos de la base	A.8.12, A.8.13, A.8.10, A.5.33	2×5 = 10 Alto TDE (PR-15) y RMAN cifrado (PR-16) impiden leer datafiles y respaldos físicos. Pero un export de Data Pump guarda en claro incluso los datos TDE (ORA-39173) y Free no permite cifrarlo (ORA-00439): si un export sale del servidor, el impacto sigue siendo máximo. Keystore AUTO_LOGIN en el mismo servidor (P-04).

ID	Activo	Amenaza / vulnerabilidad	Escenario	P	I	Inherente	Justificación	Controles	Residual (tras verificar)
R-CONF-04	Copias DEV/TEST y consultas de soporte	**Amenaza:** Exposición a personal no autorizado **Vulnerabilidad:** Datos reales copiados a ambientes con menos controles	Se clona el PDB a desarrollo con tarjetas y cédulas reales	4	4	16 Crítico	Clonar producción sin enmascarar es una práctica común; los desarrolladores no necesitan datos reales	A.8.11, A.5.12, A.8.3	1×4 = 4 Bajo La copia DEV tiene 0 coincidencias con datos reales (VC-11) y soporte ve los datos enmascarados (PR-04).
R-CONF-05	Rastro de auditoría	**Amenaza:** Fuga no detectada o encubierta **Vulnerabilidad:** Sin políticas que registren el acceso a datos sensibles; rastro modificable	Alguien consulta datos de clientes y no queda registro de quién, cuándo ni qué	4	4	16 Crítico	La auditoría unificada está activa por defecto, pero sin políticas sobre los objetos sensibles no registra esos SELECT	A.8.15, A.5.33, A.8.2	2×4 = 8 Medio Políticas sobre datos, privilegios y controles (VC-14), auditor separado (PR-08/PR-09). Sin SIEM externo, SYS aún puede actuar sobre el rastro.
R-CONF-06	Tráfico cliente-servidor	**Amenaza:** Interceptación en la red **Vulnerabilidad:** Tráfico sin cifrar o listener expuesto	Se captura en la red una consulta con datos de clientes	3	4	12 Alto	Sin cifrado de red el tráfico SQL viaja en claro	A.8.20, A.8.5	1×4 = 4 Bajo El servidor exige AES256/SHA256 (VC-15) y rechaza clientes sin cifrado (PR-18); puerto solo en localhost. Falta TLS con certificado (P-03).

4. Tareas DBA

ID	Tarea crítica del DBA	Implementación en Oracle	¿Demostrable en este entorno?	Scripts / pruebas
T01	Gestión de usuarios	Una cuenta por persona; esquemas dueños sin autenticación (NO AUTHENTICATION); cuentas obsoletas bloqueadas	Sí	`03, VC-03, A-01`
T02	Gestión de privilegios y roles	Roles por función (VENDEDORES, SOPORTE_CONSULTA); sin ANY ni PUBLIC; cambios solo por procedimiento	Sí	`03, VC-02, VC-07, PR-05, PR-06`
T03	Revisión periódica de accesos	Privilege Analysis (DBMS_PRIVILEGE_CAPTURE): privilegios usados y no usados	Sí	`PR-00, PR-99, VC-05`
T04	Autenticación y perfiles	Perfil con verificación de complejidad, bloqueo por intentos, vigencia e IDLE_TIME	Sí	`03, VC-04, VC-09, PR-11, PR-12, PR-13`
T05	Gestión de cuentas privilegiadas	Auditor separado (AUDIT_VIEWER sin AUDIT_ADMIN); auditoría del uso de privilegios amplios y de cambios a reglas	Parcial Una sola persona administra el laboratorio; Database Vault queda propuesto	`07, PR-08, PR-09, PR-19, A-02`
T06	Cifrado TDE	Keystore de software, clave maestra AES256, tablespace cifrado TS_CONFIDENCIAL	Sí En Free no hay cifrado en línea de tablespaces existentes; keystore AUTO_LOGIN local	`01, 02, VC-12, PR-15`
T07	Enmascaramiento	Dinámico con Data Redaction (tarjeta, cédula, correo); estático con SQL para la copia DEV	Sí El Data Masking Pack de Enterprise Manager no se usa; se implementa el mismo principio con SQL	`06, 09, VC-11, PR-03, PR-04`
T08	Restricción por filas (VPD)	DBMS_RLS con reglas por usuario y denegación por defecto	Sí	`05, VC-08, PR-01, PR-02, PR-10`
T09	Respaldos cifrados	RMAN con cifrado AES256 por defecto (keystore TDE); respaldo del keystore; directorio de exportación restringido	Parcial Oracle Free no permite cifrar exports de Data Pump (ORA-00439); se documenta openssl como alternativa externa	`10_rman_cifrado.sh, PR-16, VC-13`
T10	Auditoría	4 políticas de auditoría unificada + FGA sobre TARJETA; política adicional tras Actuar	Sí	`07, VC-14, PR-14, A-02`
T11	Gestión de logs	Retención de 90 días y job de purga controlada; límites de redo/LogMiner documentados	Parcial No hay SIEM real; envío por syslog propuesto (P-05)	`08, VC-06`
T12	Parcheo	Registro de la versión (V$VERSION, DBA_REGISTRY_SQLPATCH) para compararla con el último Release Update	Parcial Solo evidencia de versión; en Free el parche se aplica con una imagen nueva	`00 (E-00), A-03 P-07`

ID	Tarea crítica del DBA	Implementación en Oracle	¿Demostrable en este entorno?	Scripts / pruebas
T13	Listener y configuración de red	Cifrado nativo requerido (AES256/SHA256); puerto publicado solo en 127.0.0.1	Sí TLS con certificados queda propuesto (P-03)	`aplicar_cifrado_red.sh, VC-15, PR-18`
T14	Eliminación segura	DROP ... PURGE, papelera vacía, borrado de exports con shred; tablespaces INCLUDING CONTENTS AND DATAFILES	Parcial El borrado físico de medios no se puede garantizar (SSD, capas de Docker)	`PR-17, VC-10, PR-16, 99`
T15	Clones de desarrollo y pruebas	Copia VENTAS_DEV con enmascaramiento estático y formato preservado	Parcial Simula el resultado del clon; no se clona el PDB completo por los límites de Free	`09, VC-11, PR-10`

5. Controles ISO

ISO/IEC 27001:2022 define los requisitos certificables de un SGSI (cláusulas 4 a 10). Su **Anexo A** es un catálogo de 93 controles de referencia, de los que la organización selecciona los aplicables y lo declara en la Declaración de Aplicabilidad. **ISO/IEC 27002:2022** no es certificable: explica el propósito y la guía de implementación de cada control. En este trabajo se distingue además el **control ISO** (qué se busca, por ejemplo A.8.2) de la **comprobación técnica** que permite observarlo en Oracle (por ejemplo VC-07, que consulta DBA_SYS_PRIVS).

Control	Título (traducción propia)	Tema	Pertinencia para la confidencialidad	Riesgos	Tareas	Implementación en Oracle	Evidencia observable	Limitaciones
A.5.12	Clasificación de la información	Organizacional	Sin saber qué es confidencial no se puede decidir qué cifrar, enmascarar o auditar.	R-CONF-01, R-CONF-04	T07, T15	Etiquetas [INTERNO]/[CONFIDENCIAL]/[RESTRINGIDO] en el diccionario (COMMENT ON COLUMN)	`DBA_COL_COMMENTS (VC-01)`	Documenta la clasificación; no protege por sí misma ni valida que sea correcta
A.5.15	Control de acceso	Organizacional	Define quién puede acceder a qué; es la base del mínimo privilegio.	R-CONF-01	T02	Acceso solo por roles de función; nada a PUBLIC; cambios por procedimiento	`DBA_TAB_PRIVS, DBA_ROLE_PRIVS (VC-02); PR-05, PR-06, PR-07`	No cubre privilegios de sistema (ver A.8.2)
A.5.16	Gestión de identidades	Organizacional	Una identidad por persona permite atribuir cada acceso.	R-CONF-02	T01	Cuentas individuales, esquemas NO AUTHENTICATION, sin contraseñas por defecto	`DBA_USERS, DBA_USERS_WITH_DEFPWD (VC-03)`	No detecta cuentas compartidas de hecho
A.5.17	Información de autenticación	Organizacional	Contraseñas débiles anulan cualquier control de acceso.	R-CONF-02	T04	PASSWORD_VERIFY_FUNCTION, vigencia y no reutilización	`DBA_PROFILES (VC-04); PR-11 (ORA-28003)`	El perfil DEFAULT (global) no se modificó
A.5.18	Derechos de acceso	Organizacional	Los derechos deben revisarse y retirarse cuando ya no se necesitan.	R-CONF-01	T02, T03	Privilege Analysis y revocación (A-01)	`DBA_USED_PRIVS / DBA_UNUSED_PRIVS (VC-05)`	Refleja solo el período capturado

Control	Título (traducción propia)	Tema	Pertinencia para la confidencialidad	Riesgos	Tareas	Implementación en Oracle	Evidencia observable	Limitaciones
A.5.33	Protección de registros	Organizacional	Los registros de auditoría solo sirven si no se pueden alterar ni borrar sin control.	R-CONF-03, R-CONF-05	T10, T11	AUDSYS bloqueada, auditor sin AUDIT_ADMIN, retención y purga controlada	`DBA_AUDIT_MGMT_* (VC-06); PR-09`	SYS puede actuar sobre el rastro; falta copia externa (SIEM)
A.8.2	Derechos de acceso privilegiado	Tecnológico	Las cuentas privilegiadas pueden saltarse los controles; deben ser mínimas y vigiladas.	R-CONF-01, R-CONF-05	T05	Sin DBA/ANY/EXEMPT en cuentas comunes; auditoría de SELECT ANY TABLE y de cambios a reglas	`DBA_ROLE_PRIVS, DBA_SYS_PRIVS (VC-07); PR-10, PR-19`	El DBA sigue pudiendo alterar reglas: se detecta, no se impide (Database Vault propuesto)
A.8.3	Restricción del acceso a la información	Tecnológico	Limita el acceso a las filas y columnas que cada función necesita.	R-CONF-01, R-CONF-04	T07, T08	VPD con denegación por defecto + Data Redaction	`DBA_POLICIES (VC-08); PR-01, PR-02, PR-10`	SYS y EXEMPT ACCESS POLICY no se ven afectados
A.8.5	Autenticación segura	Tecnológico	Impide la suplantación por fuerza bruta o por sesiones abandonadas.	R-CONF-02, R-CONF-06	T04, T13	FAILED_LOGIN_ATTEMPTS, PASSWORD_LOCK_TIME, IDLE_TIME, verificadores 12C	`DBA_PROFILES, DBA_USERS (VC-09); PR-12 (ORA-28000), PR-13 (ORA-02396)`	Sin segundo factor (MFA)
A.8.10	Eliminación de información	Tecnológico	Un dato «borrado» que sigue recuperable sigue siendo un riesgo de confidencialidad.	R-CONF-03	T14	PURGE, papelera vacía, shred de exports, borrado de datafiles	`DBA_RECYCLEBIN (VC-10); PR-17, PR-16`	No garantiza borrado físico en SSD/capas; la protección real es el cifrado

Control	Título (traducción propia)	Tema	Pertinencia para la confidencialidad	Riesgos	Tareas	Implementación en Oracle	Evidencia observable	Limitaciones
A.8.11	Enmascaramiento de datos	Tecnológico	Permite usar los datos sin exponer su valor real.	R-CONF-04	T07, T15	Data Redaction (dinámico) y copia DEV con valores falsos (estático)	`REDACTION_COLUMNS y comparación DEV-producción (VC-11); PR-03, PR-04`	Redaction no aplica a cuentas exentas (rol DBA); posible inferencia con WHERE
A.8.12	Prevención de fuga de datos	Tecnológico	Evita que los datos salgan de su ámbito por copia de archivos o extracción masiva.	R-CONF-03, R-CONF-05	T06, T09, T10	TDE en tablespace cifrado + RMAN cifrado + auditoría de lecturas y privilegios amplios	`DBA_TABLESPACES, V$ENCRYPTED_TABLESPACES (VC-12); PR-15, PR-16`	Los exports de Data Pump quedan en claro en Free; DLP completo incluye correo, USB, nube: fuera del alcance del DBA
A.8.13	Respaldo de la información	Tecnológico	Un respaldo es una copia completa: debe tener la misma protección que la base.	R-CONF-03	T09	RMAN cifra por defecto (AES256, keystore TDE), respaldo del keystore, directorio de exportación restringido	`V$RMAN_CONFIGURATION, V$OPTION, listado del keystore (VC-13); PR-16`	Exports lógicos no cifrables en Free (ORA-00439); keystore y datos en el mismo servidor; disponibilidad fuera de alcance
A.8.15	Registro (logging)	Tecnológico	Sin registros no se puede detectar ni investigar un acceso indebido.	R-CONF-05	T10, T11	Auditoría unificada (datos, accesos, privilegios, controles) + FGA	`AUDIT_UNIFIED_ENABLED_POLICIES, UNIFIED_AUDIT_TRAIL (VC-14); PR-14`	Detecta, no impide; redo/LogMiner no registran SELECT

Control	Título (traducción propia)	Tema	Pertinencia para la confidencialidad	Riesgos	Tareas	Implementación en Oracle	Evidencia observable	Limitaciones
A.8.20	Seguridad de redes	Tecnológico	Los datos y credenciales viajan por la red entre cliente y servidor.	R-CONF-06	T13	SQLNET.ENCRYPTION_SERVER=REQUIRED (AES256, SHA256); puerto solo local	`V$SESSION_CONNECT_INFO`, `sqlnet.ora (VC-15); PR-18 (ORA-12660)`	NNE no autentica al servidor; TLS propuesto

6. Observables

ID	Control ISO	Comprobación observable	Técnica / vista	Criterio de aceptación	Resultado registrado
VC-01	A.5.12	Toda columna de CLIENTES y VENTAS tiene etiqueta de clasificación en el diccionario	Consulta a DBA_TAB_COLUMNS + DBA_COL_COMMENTS	0 columnas sin etiqueta [INTERNO|CONFIDENCIAL|RESTRINGIDO]	`evidencias/VC-01_clasificacion.txt` : Cumple
VC-02	A.5.15	El acceso a datos de negocio se concede solo por roles; nada a PUBLIC	DBA_TAB_PRIVS cruzado con DBA_ROLES	0 concesiones a PUBLIC y 0 directas a usuarios	`evidencias/VC-02_control_acceso_roles.txt` : Cumple
VC-03	A.5.16	Sin contraseñas por defecto; esquemas sin inicio de sesión; personas con perfil seguro	DBA_USERS, DBA_USERS_WITH_DEFPWD	0 cuentas con contraseña por defecto; 3 esquemas NO AUTHENTICATION; 0 personas fuera del perfil	`evidencias/VC-03_identidades.txt` : Cumple
VC-04	A.5.17	Contraseñas con función de complejidad, vigencia y no reutilización	DBA_PROFILES (PERFIL_CONFIDENCIAL y DEFAULT)	CUMPLE: ambos perfiles; PARCIAL: solo el perfil del laboratorio	`evidencias/VC-04_informacion_autenticacion.txt` : Parcial
VC-05	A.5.18	Revisión objetiva de derechos con Privilege Analysis	DBA_USED_PRIVS / DBA_UNUSED_PRIVS de la captura CAP_LAB_CONF	CUMPLE: 0 privilegios sin uso; PARCIAL: hay privilegios sin uso por revisar	`evidencias/VC-05_revision_derechos.txt` : Parcial
VC-06	A.5.33	Rastro de auditoría protegido y con retención controlada	DBA_USERS (AUDSYS), DBA_ROLE_PRIVS, DBA_AUDIT_MGMT_*	AUDSYS sin login; 0 cuentas de laboratorio con AUDIT_ADMIN; job de purga habilitado	`evidencias/VC-06_proteccion_registros.txt` : Cumple
VC-07	A.8.2	Ninguna cuenta común con rol DBA, privilegios ANY o exenciones	DBA_ROLE_PRIVS, DBA_SYS_PRIVS (ORACLE_MAINTAINED = 'N')	0 hallazgos	`evidencias/VC-07_acceso_privilegiado.txt` : No cumple `evidencias/VC-07_acceso_privilegiado_DESPUES.txt` : Cumple
VC-08	A.8.3	VPD habilitado en las tablas con datos personales y sin cuentas comunes exentas	DBA_POLICIES; jerarquía de roles con EXEMPT ACCESS POLICY	2 tablas protegidas para las 4 operaciones; 0 cuentas comunes exentas	`evidencias/VC-08_restriccion_acceso.txt` : Cumple

ID	Control ISO	Comprobación observable	Técnica / vista	Criterio de aceptación	Resultado registrado
VC-09	A.8.5	Bloqueo por intentos, IDLE_TIME, verificadores modernos y RESOURCE_LIMIT	DBA_PROFILES, DBA_USERS.PASSWORD_VERSIONS, V$PARAMETER	FAILED_LOGIN_ATTEMPTS <= 5 con bloqueo, IDLE_TIME definido, sin verificador 10G, RESOURCE_LIMIT = TRUE	`evidencias/VC-09_autenticacion_segura.txt` : Cumple
VC-10	A.8.10	Sin copias recuperables en la papelera de reciclaje	DBA_RECYCLEBIN	0 objetos de VENTAS_LAB/VENTAS_DEV en la papelera	`evidencias/VC-10_eliminacion.txt` : Cumple
VC-11	A.8.11	Redaction sobre 3 columnas y copia DEV sin valores reales	REDACTION_POLICIES/COLUMNS; comparación DEV contra producción (SYSDBA)	3 columnas redactadas; 0 coincidencias reales	`evidencias/VC-11_enmascaramiento.txt` : Cumple
VC-12	A.8.12	Datos personales en tablespace cifrado + auditoría de lecturas y privilegios amplios	DBA_TABLESPACES, V$ENCRYPTED_TABLESPACES, V$ENCRYPTION_WALLET, AUDIT_UNIFIED_ENABLED_POLICIES	2 tablas en TS cifrado, keystore OPEN, 2 políticas de detección	`evidencias/VC-12_prevencion_fuga.txt` : Cumple
VC-13	A.8.13	Respaldos RMAN cifrados por defecto, keystore respaldado y directorio de export restringido	V$RMAN_CONFIGURATION, V$OPTION, listado del keystore, DBA_TAB_PRIVS	ENCRYPTION FOR DATABASE = ON; Backup Encryption = TRUE; 0 concesiones indebidas	`evidencias/VC-13_respaldo.txt` : Cumple
VC-14	A.8.15	Políticas de auditoría habilitadas y registros reales de las pruebas	AUDIT_UNIFIED_ENABLED_POLICIES, DBA_AUDIT_POLICIES, UNIFIED_AUDIT_TRAIL	>= 4 políticas + FGA; registros de JUAN, ANA y SOPORTE_LAB; al menos un rechazo registrado	`evidencias/VC-14_registro_eventos.txt` : Cumple `evidencias/VC-14_registro_eventos_DESPUES.txt` : Cumple
VC-15	A.8.20	Sesión de red cifrada con AES256 e integridad SHA256	V$SESSION_CONNECT_INFO; sqlnet.ora del servidor	Banners con AES256 y SHA256	`evidencias/VC-15_seguridad_red.txt` : Cumple `evidencias/E-10_red.txt`

7. Matriz

La MADUREZ (0-4) mide qué tan sólido y sostenido es el control. El ESTADO (Cumple, Parcial, No cumple, Pendiente de evaluación) indica si la evidencia satisface el criterio de la comprobación en el laboratorio. Un control puede «Cumplir» su comprobación y tener madurez 3, no 4, porque falta la operación periódica.

Seguimiento histórico. Esta tabla muestra la evaluación registrada al cierre del laboratorio (pruebas ejecutadas el 21/10/2026 23:15–23:48). En el artefacto, el módulo «Matriz y seguimiento» permite registrar nuevas evaluaciones de cada control en distintas fechas (madurez 0–4, estado con semáforo, evidencia y observaciones), consultar su historial y comparar la evolución de varios controles en una gráfica filtrada por fechas. Ver `docs/seguimiento-evaluaciones.md`.

Nivel	Nombre	Significado
0	Inexistente	No hay configuración ni procedimiento para el control.
1	Inicial	Se hace de forma manual u ocasional, sin configuración técnica que lo garantice.
2	Implementado parcialmente	Hay configuración técnica, pero no cubre todo el alcance o no se ha comprobado.
3	Implementado y verificado	La configuración cubre el alcance del laboratorio y un script de verificación más pruebas positivas y negativas lo demuestran con evidencia.
4	Gestionado	Además de 3: se ejecuta de forma periódica o automática, tiene responsables y alertas, y sus registros se conservan fuera del alcance del administrador.

Tarea	Riesgo	Control	Criterios 0–4 (el resaltado es el nivel alcanzado)	Madurez asignada	Evidencia	Estado
T07, T15	R-CONF-01, R-CONF-04	**A.5.12**	**0** Sin inventario de datos sensibles **1** Clasificación en documentos aparte, no vinculada a la base **2** Algunas columnas etiquetadas en el diccionario **3 Todas las columnas de negocio etiquetadas y verificadas por script (VC-01)** **4** Además, la clasificación se revisa periódicamente y alimenta automáticamente Redaction y auditoría	**3** Las 13 columnas están etiquetadas y VC-01 lo comprueba. No hay revisión periódica ni descubrimiento automático.	`VC-01, E-04` VC-01_clasificacion: CUMPLE	Cumple

Tarea	Riesgo	Control	Criterios 0–4 (el resaltado es el nivel alcanzado)	Madurez asignada	Evidencia	Estado
T02	R-CONF-01	**A.5.15**	**0** Acceso con cuentas compartidas o con DBA **1** Permisos directos a personas, sin política **2** Roles por función, pero con excepciones directas o a PUBLIC **3 Solo roles por función, nada a PUBLIC; pruebas negativas lo demuestran (VC-02, PR-05/06/07)** **4** Además, altas y bajas de roles por flujo aprobado y revisión periódica	**3** Todo el acceso pasa por roles; las pruebas negativas fueron rechazadas. No existe un flujo formal de aprobación.	`VC-02, PR-05, PR-06, PR-07` VC-02_control_acceso_roles: CUMPLE	Cumple
T01	R-CONF-02	**A.5.16**	**0** Cuentas genéricas o compartidas **1** Cuentas individuales, pero con contraseñas por defecto o esquemas con login **2** Cuentas individuales; esquemas aún con login **3 Cuentas individuales, esquemas NO AUTHENTICATION, sin contraseñas por defecto (VC-03)** **4** Además, ciclo de vida integrado con RR. HH./IAM y bajas automáticas	**3** Se cumple el criterio técnico. No hay integración con un sistema de identidades.	`VC-03, E-03` VC-03_identidades: CUMPLE	Cumple
T04	R-CONF-02	**A.5.17**	**0** Sin reglas de contraseña **1** Reglas escritas, no aplicadas por la base **2 Función de verificación solo en parte de las cuentas** **3** Función de verificación, vigencia y no reutilización en TODAS las cuentas, probado con PR-11 **4** Además, gestor de secretos o autenticación centralizada	**2** El perfil del laboratorio cumple y PR-11 lo demuestra, pero el perfil DEFAULT (resto de cuentas) no tiene función de verificación: alcance parcial.	`VC-04, PR-11` VC-04_informacion_autenticacion: PARCIAL	Parcial

Tarea	Riesgo	Control	Criterios 0–4 (el resaltado es el nivel alcanzado)	Madurez asignada	Evidencia	Estado
T02, T03	R-CONF-01	**A.5.18**	**0** Nunca se revisan los derechos **1** Revisión manual ocasional sin evidencia **2 Revisión con herramienta (Privilege Analysis) sin acciones derivadas** **3** Revisión con herramienta, hallazgos corregidos y re-verificados **4** Además, revisión programada (p. ej., trimestral) con aprobación del dueño de la información	**2** Privilege Analysis identificó privilegios sin uso, pero aún no se decidió su revocación (requiere al dueño del proceso). La revocación de A-01 provino de VC-07.	`VC-05, PR-00, PR-99` VC-05_revision_derechos: PARCIAL	Parcial
T10, T11	R-CONF-03, R-CONF-05	**A.5.33**	**0** Sin auditoría o con el rastro modificable por cualquiera **1** Rastro activo sin control de acceso **2** Rastro con acceso restringido, sin retención definida **3 Rastro protegido (AUDSYS sin login, auditor sin AUDIT_ADMIN) y retención con purga controlada (VC-06, PR-09)** **4** Además, copia inmutable fuera de la base (SIEM/WORM)	**3** Rastro protegido y con retención. No hay copia externa: SYS aún puede actuar sobre él.	`VC-06, PR-09, E-08` VC-06_proteccion_registros: CUMPLE	Cumple
T05	R-CONF-01, R-CONF-05	**A.8.2**	**0** Varias cuentas comunes con DBA o ANY **1** Privilegios amplios identificados sin corregir **2** Sin privilegios amplios en cuentas comunes, pero sin vigilar a los administradores **3 Sin privilegios amplios en cuentas comunes (VC-07 después) y uso de privilegios amplios auditado (PR-14, PR-19)** **4** Además, separación técnica del DBA respecto de los datos (Database Vault) y acceso privilegiado temporal (PAM)	**3** VC-07 detectó APP_RIESGO (NO CUMPLE) y tras A-01 dio CUMPLE. El DBA todavía puede alterar las reglas (PR-19): se detecta, no se impide.	`VC-07 antes/después, PR-10, PR-19, A-01, A-02` VC-07_acceso_privilegiado: NO CUMPLE → VC-07_acceso_privilegiado_DESPUES: CUMPLE	Cumple

Tarea	Riesgo	Control	Criterios 0–4 (el resaltado es el nivel alcanzado)	Madurez asignada	Evidencia	Estado
T07, T08	R-CONF-01, R-CONF-04	**A.8.3**	**0** Cualquier usuario con acceso a la tabla ve todo **1** Restricción solo en la aplicación **2** VPD o vistas en parte de las tablas **3 VPD con denegación por defecto en todas las tablas personales, sin cuentas comunes exentas, probado (VC-08, PR-01/02/10)** **4** Además, reglas gestionadas fuera del alcance del DBA y revisadas periódicamente	**3** VPD filtra a JUAN, ANA y bloquea a APP_RIESGO. La tabla de reglas es modificable por un DBA (PR-19).	`VC-08, PR-01, PR-02, PR-10` VC-08_restriccion_acceso: CUMPLE	Cumple
T04, T13	R-CONF-02, R-CONF-06	**A.8.5**	**0** Sin bloqueo ni límites de sesión **1** Bloqueo configurado sin probar **2** Bloqueo e inactividad solo en algunas cuentas **3 Bloqueo, IDLE_TIME y verificadores 12C probados (VC-09, PR-12, PR-13)** **4** Además, MFA o autenticación centralizada (Kerberos/IAM)	**3** Bloqueo e inactividad demostrados con ORA-28000 y ORA-02396. No hay MFA.	`VC-09, PR-12, PR-13` VC-09_autenticacion_segura: CUMPLE	Cumple
T14	R-CONF-03	**A.8.10**	**0** Los borrados dejan copias recuperables sin control **1** Se borra manualmente sin verificar **2** Se usa PURGE, sin procedimiento para exports ni respaldos **3 Papelera sin datos sensibles (VC-10), PURGE demostrado (PR-17) y exports borrados (PR-16)** **4** Además, política de retención automatizada y borrado criptográfico de respaldos	**3** Demostrado en la base. El borrado físico en SSD/Docker no se puede garantizar; no hay retención automatizada.	`VC-10, PR-17, PR-16` VC-10_eliminacion: CUMPLE	Cumple

Tarea	Riesgo	Control	Criterios 0–4 (el resaltado es el nivel alcanzado)	Madurez asignada	Evidencia	Estado
T07, T15	R-CONF-04	**A.8.11**	**0** Datos reales visibles para todos y copiados a desarrollo **1** Enmascaramiento manual ocasional **2** Enmascaramiento solo dinámico o solo estático **3 Dinámico (Redaction) y estático (copia DEV) verificados (VC-11, PR-03/04/10)** **4** Además, enmascaramiento automático en cada clon y pruebas contra inferencia	**3** Ambos tipos verificados. El rol DBA está exento de Redaction y la copia DEV se genera con un script manual.	`VC-11, PR-03, PR-04, PR-10` VC-11_enmascaramiento: CUMPLE	Cumple
T06, T09, T10	R-CONF-03, R-CONF-05	**A.8.12**	**0** Datos en claro en archivos y sin detección **1** Solo una medida (cifrado o auditoría) **2 Cifrado y detección, con vías de fuga conocidas sin cubrir** **3** TDE probado (PR-15) y detección de lecturas/privilegios amplios (VC-12, PR-14); todas las vías de copia cubiertas **4** Además, DLP de red/endpoint y alertas automáticas	**2** TDE y auditoría funcionan, pero PR-16 mostró que un export de Data Pump guarda en claro los datos TDE (ORA-39173) y Free no permite cifrarlo: hay una vía de fuga que depende de procedimiento.	`VC-12, PR-15, PR-16` VC-12_prevencion_fuga: CUMPLE	Parcial VC-12 da CUMPLE (TDE + detección), pero PR-16 demostró una vía de fuga: el export de Data Pump guarda en claro los datos TDE y Free no permite cifrarlo.
T09	R-CONF-03	**A.8.13**	**0** Respaldos en claro y accesibles **1** Respaldos en claro con acceso restringido **2 Algunos respaldos cifrados** **3** Todos los respaldos físicos cifrados (RMAN), keystore respaldado y exports controlados (VC-13, PR-16) **4** Además, keystore fuera del servidor (HSM/OKV) y pruebas de restauración	**2** RMAN cifra por defecto (verificado), pero los exports lógicos no se pueden cifrar en Free y el keystore está en el mismo servidor.	`VC-13, PR-16, E-11` VC-13_respaldo: CUMPLE	Parcial VC-13 da CUMPLE para RMAN, pero los exports lógicos no se pueden cifrar en Free (ORA-00439) y el keystore está en el mismo servidor.

Tarea	Riesgo	Control	Criterios 0–4 (el resaltado es el nivel alcanzado)	Madurez asignada	Evidencia	Estado
T10, T11	R-CONF-05	**A.8.15**	**0** Sin auditoría **1** Solo auditoría por defecto de Oracle **2** Políticas propias sin revisar sus registros **3 Políticas sobre datos, accesos, privilegios y controles, con registros reales revisados (VC-14, PR-14)** **4** Además, envío a SIEM con correlación y alertas	**3** Los registros muestran quién, cuándo, qué y el resultado. No hay SIEM.	`VC-14 antes/después, PR-14, PR-19` VC-14_registro_eventos: CUMPLE → VC-14_registro_eventos_DESPUES: CUMPLE	Cumple
T13	R-CONF-06	**A.8.20**	**0** Tráfico en claro y puerto expuesto **1** Puerto restringido, tráfico en claro **2** Cifrado opcional (REQUESTED) **3 Cifrado obligatorio AES256/SHA256 probado con cliente rechazado (VC-15, PR-18) y puerto solo local** **4** Además, TLS con certificados y autenticación del servidor	**3** Cifrado nativo obligatorio demostrado. Falta TLS con certificado.	`VC-15, PR-18, E-10` VC-15_seguridad_red: CUMPLE	Cumple

8. Pruebas

ID	Tipo	Control	Usuario / privilegios	Procedimiento	Resultado esperado	Herramienta	Resultado obtenido	Evidencia
PR-01	Positiva	A.8.3	JUAN (rol VENDEDORES)	Consultar CLIENTES agrupando por vendedor	10 filas, todas de JUAN	SQL*Plus / SQL Developer	Coincide	`evidencias/PR-01_vpd_juan.txt`
PR-02	Negativa	A.8.3	ANA (rol VENDEDORES)	Buscar el cliente 1 (de JUAN) y registrarle una venta	ANA ve solo sus 10 clientes; el cliente 1 no existe para ella; ORA-20002	SQL*Plus / SQL Developer	Coincide	`evidencias/PR-02_vpd_ana.txt`
PR-03	Positiva	A.8.11	JUAN	Consultar cédula, correo y tarjeta	Cédula y correo visibles; tarjeta ****-****-****-NNNN	SQL*Plus / SQL Developer	Coincide	`evidencias/PR-03_redaction_vendedor.txt`
PR-04	Positiva	A.8.11	SOPORTE_LAB	Consultar todos los clientes	20 filas con cédula *-****-NNNN, correo xxxx@dominio y tarjeta enmascarada	SQL*Plus / SQL Developer	Coincide	`evidencias/PR-04_redaction_soporte.txt`
PR-05	Negativa	A.5.15	JUAN	DELETE y UPDATE sobre CLIENTES	Rechazo por falta de privilegio (ORA-41900 en 26ai; ORA-01031 en 19c/21c)	SQL*Plus / SQL Developer	Coincide	`evidencias/PR-05_borrado_denegado.txt`
PR-06	Positiva y negativa	A.5.15	JUAN	INSERT directo en VENTAS; luego REGISTRAR_VENTA con cliente propio y ajeno	INSERT rechazado (ORA-41900); procedimiento exitoso con cliente propio; ORA-20002 con cliente ajeno	SQL*Plus / SQL Developer	Coincide	`evidencias/PR-06_procedimiento.txt`
PR-07	Negativa	A.5.15	SOPORTE_LAB	Consultar VENTAS	ORA-00942 (la tabla no existe para soporte)	SQL*Plus / SQL Developer	Coincide	`evidencias/PR-07_soporte_sin_ventas.txt`
PR-08	Positiva y negativa	A.8.2	AUDITOR_LAB (AUDIT_VIEWER)	Consultar CLIENTES y luego UNIFIED_AUDIT_TRAIL	ORA-00942 sobre datos; conteo de auditoría > 0	SQL*Plus / SQL Developer	Coincide	`evidencias/PR-08_auditor_separacion.txt`
PR-09	Negativa	A.5.33	AUDITOR_LAB	NOAUDIT POLICY y CREATE AUDIT POLICY	ORA-01031 y ORA-41732	SQL*Plus / SQL Developer	Coincide	`evidencias/PR-09_auditor_no_administra.txt`

ID	Tipo	Control	Usuario / privilegios	Procedimiento	Resultado esperado	Herramienta	Resultado obtenido	Evidencia
PR-10	Negativa (defensa en profundidad)	A.8.2	APP_RIESGO (SELECT ANY TABLE)	Consultar CLIENTES, la copia DEV y la tabla de reglas	0 filas en CLIENTES (VPD); copia DEV solo con datos falsos; HALLAZGO: lee las reglas de seguridad	SQL*Plus / SQL Developer	Coincide	`evidencias/PR-10_sobreprivilegiada.txt`
PR-11	Negativa	A.5.17	JUAN	Cambiar la contraseña por «JUAN», «Ju4n!» y «vendedorjuan»	Las tres rechazadas con ORA-28003	SQL*Plus (PL/SQL)	Coincide	`evidencias/PR-11_contrasena_debil.txt`
PR-12	Negativa	A.8.5	PRUEBA_BLOQUEO	3 inicios de sesión con contraseña incorrecta y uno con la correcta	3 x ORA-01017, luego ORA-28000; estado LOCKED(TIMED); intentos auditados	SQL*Plus	Coincide	`evidencias/PR-12_bloqueo.txt`
PR-13	Negativa	A.8.5	PRUEBA_IDLE (IDLE_TIME = 1)	Dejar la sesión inactiva 3 minutos y consultar	ORA-02396 exceeded maximum idle time	SQL*Plus	Coincide	`evidencias/PR-13_idle_time.txt`
PR-14	Positiva	A.8.15	AUDITOR_LAB	Consultar UNIFIED_AUDIT_TRAIL de la última hora	Eventos con usuario, hora, acción, objeto, SQL y código; rechazos; uso de SELECT ANY TABLE	SQL*Plus / SQL Developer	Coincide	`evidencias/PR-14_auditoria.txt`
PR-15	Positiva	A.8.12	SYSDBA (simula copia de archivos)	Buscar el marcador con strings en el datafile normal y en el cifrado	Marcador visible en el no cifrado; 0 coincidencias en el cifrado	SQL*Plus + strings	Coincide	`evidencias/PR-15_tde_archivos.txt`
PR-16	Positiva, negativa y hallazgo	A.8.13	SYSTEM (Data Pump) / SYSDBA (RMAN)	Export normal, export cifrado, respaldos RMAN sin y con cifrado, cifrado del .dmp con openssl, borrado	Export normal en claro (ORA-39173); ORA-00439 en export cifrado; RMAN cifrado sin marcador; .dmp.enc sin marcador; 0 archivos restantes	Data Pump, RMAN, strings, openssl, shred	Coincide	`evidencias/PR-16_respaldos_cifrados.txt`
PR-17	Negativa y corrección	A.8.10	SYSTEM	DROP TABLE sin PURGE, leer BIN$..., luego PURGE	El dato «borrado» se lee desde la papelera; tras PURGE, 0 objetos	SQL*Plus / SQL Developer	Coincide	`evidencias/PR-17_papelera.txt`
PR-18	Positiva y negativa	A.8.20	JUAN	Conectar con cliente normal y con cliente que rechaza cifrado	Sesión con AES256/SHA256; ORA-12660 para el cliente sin cifrado	SQL*Plus + sqlnet.ora de cliente	Coincide	`evidencias/PR-18_cliente_sin_cifrado.txt`
PR-19	Riesgo residual (antes y después de Actuar)	A.8.2 / A.8.15	SYSTEM (rol DBA)	El DBA se agrega a la tabla de reglas de VPD, consulta y revierte	Antes: ve los 20 clientes y la tarjeta completa; el INSERT no queda auditado. Después de A-02: el cambio queda auditado con POL_CONF_CAMBIOS_REGLAS	SQL*Plus / SQL Developer	Coincide	`evidencias/PR-19_dba_reglas_antes.txt` `evidencias/PR-19_dba_reglas_despues.txt`

9. Actuar

Hallazgos y correcciones aplicadas

- **VC-07 (A.8.2):** la cuenta `APP_RIESGO` tenía `SELECT ANY TABLE` → NO CUMPLE. En PR-10, VPD le devolvió 0 filas de CLIENTES (defensa en profundidad), pero pudo leer la copia DEV y la tabla de reglas de seguridad. **A-01:** se revocó el privilegio y se bloqueó la cuenta. VC-07 se volvió a ejecutar → CUMPLE.
- **PR-19 (A.8.2, A.8.15):** un DBA (SYSTEM) se agregó a la tabla de reglas de VPD y vio los 20 clientes con la tarjeta completa, porque el rol DBA hereda EXEMPT REDACTION POLICY. El INSERT no quedaba auditado. **A-02:** se creó la política `POL_CONF_CAMBIOS_REGLAS`; al repetir PR-19 el cambio queda registrado. El riesgo se DETECTA, no se IMPIDE.
- **PR-16 (A.8.12, A.8.13):** un export de Data Pump guarda en claro los datos de tablas TDE (ORA-39173) y Oracle Free no permite cifrar exports (ORA-00439). Se configuró RMAN para cifrar todos los respaldos físicos (E-11, VC-13). Para exports se documenta el cifrado con openssl como alternativa, que ofrece una protección distinta porque la clave queda fuera de Oracle.
- **VC-01 (A.5.12):** en la primera ejecución detectó 4 columnas de VENTAS sin clasificar; se corrigió el script 04 y la verificación pasó a CUMPLE.

Propuestas no ejecutadas (riesgo residual)

Están documentadas, con las sentencias comentadas, en `sql/40_actuar/A-03_propuestas_no_ejecutadas.sql`:

- **P-01:** endurecer el perfil DEFAULT, que es una política global de la base.
- **P-02:** Database Vault. Está incluido en Free, pero en este motor figura deshabilitado (`V$OPTION` = FALSE).
- **P-03:** TLS con certificados.
- **P-04:** guardar el keystore en un HSM o en Oracle Key Vault (OKV).
- **P-05:** enviar la auditoría a un SIEM.
- **P-06:** cuenta de respaldo dedicada.
- **P-07:** aplicar el último Release Update.

Limitaciones

- Es un laboratorio con datos ficticios en un contenedor local, no una organización real. Las valoraciones de riesgo se basan en un escenario construido y no en mediciones.
- Aplicar estos controles no equivale a cumplir ISO/IEC 27001 ni a estar certificado: no se implementó un SGSI (alcance, políticas, declaración de aplicabilidad, auditorías internas).
- No se tuvo acceso al texto completo de ISO/IEC 27001/27002. Los títulos de los controles provienen de una fuente secundaria, y las traducciones al español son propias.
- Se usó Oracle AI Database 26ai Free en lugar de «19c/21c XE»: no existe 19c XE y Free es la sucesora de XE. Algunas salidas cambian respecto de 21c: por ejemplo, ORA-41900 en lugar de ORA-01031, y en 26ai solo existe la auditoría unificada.
- Los redo logs, los archived logs y LogMiner registran cambios, no consultas SELECT. Por eso no se usan como evidencia de lectura de datos confidenciales.

- No hay SIEM, HSM, TLS con certificados ni MFA. Son mejoras propuestas (fase Actuar).

10. Marco teórico

Cambios de ISO/IEC 27001:2013 a ISO/IEC 27001:2022

ISO/IEC 27001 establece los requisitos de un sistema de gestión de seguridad de la información (SGSI): contexto, liderazgo, planificación, apoyo, operación, evaluación del desempeño y mejora (cláusulas 4 a 10). Su Anexo A contiene un catálogo de controles de referencia. ISO/IEC 27002 no es certificable: explica el propósito de cada control y orienta su implementación. En la edición 2022, el Anexo A pasó de 114 controles agrupados en 14 dominios a **93 controles en 4 temas**: organizacionales (5.1–5.37), de personas (6.1–6.8), físicos (7.1–7.14) y tecnológicos (8.1–8.34). Se fusionaron controles y se añadieron 11 nuevos. Tres de los nuevos están en este trabajo: *8.10 Eliminación de información*, *8.11 Enmascaramiento de datos* y *8.12 Prevención de fuga de datos*. ISO/IEC 27002:2022 añadió además atributos para clasificar los controles (por ejemplo, el tipo de control y la propiedad que protegen: confidencialidad, integridad o disponibilidad). En el cuerpo de ISO/IEC 27001 apareció una nueva cláusula 6.3 sobre la planificación de cambios. Las organizaciones certificadas con la edición 2013 tuvieron hasta el 31 de octubre de 2025 para adaptarse. Aplicar controles del Anexo A no equivale a certificarse: la certificación evalúa todo el SGSI, incluida la declaración de aplicabilidad, mediante un organismo acreditado.

Mínimo privilegio y separación de funciones en el rol de DBA

El **mínimo privilegio** consiste en conceder a cada identidad solo los permisos necesarios para su función y durante el tiempo necesario. En Oracle se aplica con roles por función (`VENDEDORES`, `SOPORTE_CONSULTA`), evitando privilegios de sistema `ANY`, concesiones a `PUBLIC` y el rol `DBA` en cuentas que no administran la base. También se aplica obligando a que los cambios pasen por procedimientos (`REGISTRAR_VENTA`) en lugar de dar `INSERT` directo. La **separación de funciones** busca que nadie controle por sí solo una operación crítica y su supervisión. En este laboratorio, el auditor puede leer el rastro (`AUDIT_VIEWER`) pero no modificarlo ni leer los datos de negocio. El DBA, en cambio, sigue siendo un riesgo residual: la prueba PR-19 muestra que un administrador con privilegios `ANY` puede alterar las reglas de acceso. Por eso los controles técnicos se complementan con auditoría y, como mejora, con Oracle Database Vault, que puede impedir que incluso un DBA lea los datos de negocio.

Defensa en profundidad y Zero Trust aplicados a bases de datos

La **defensa en profundidad** superpone controles independientes para que la falla de uno no exponga la información. El laboratorio lo demuestra con la cuenta `APP_RIESGO`: aunque tenía `SELECT ANY TABLE`, VPD le devolvió 0 filas y la copia de desarrollo solo contenía datos falsos. Si alguien copia los archivos, TDE impide leerlos, y la auditoría deja constancia del intento. **Zero Trust** (NIST SP 800-207) elimina la confianza implícita por ubicación de red: cada acceso se autentica, se autoriza con el mínimo privilegio y se evalúa de forma continua. En una base de datos esto se traduce en:

- autenticar a cada usuario con una cuenta propia y perfiles que bloquean y expiran sesiones;
- autorizar por fila y por columna (VPD y Data Redaction);
- cifrar el canal aunque la red sea «interna»;
- registrar cada acceso a datos sensibles;
- denegar por defecto: la función VPD devuelve `1 = 0` a quien no tiene una regla.

Controles técnicos de confidencialidad en Oracle

- **Transparent Data Encryption (TDE):** cifra datafiles, redo y respaldos con claves custodiadas en un keystore (wallet). Protege contra la copia de archivos, no contra un usuario autorizado que consulta por SQL. En XE y Free no se puede cifrar en línea un tablespace existente, por lo que se crea uno nuevo ya cifrado.
- **Enmascaramiento:** el *dinámico* (Oracle Data Redaction, que SQL Server llama «Dynamic Data Masking») oculta el dato al consultarlo sin cambiar lo almacenado. El *estático* reemplaza los valores en las copias para desarrollo y pruebas. Oracle lo ofrece como Data Masking and Subsetting (Enterprise Manager); aquí se implementó con SQL.
- **Seguridad a nivel de fila:** Oracle la implementa con Virtual Private Database (`DBMS_RLS`), que añade un predicado a cada sentencia. Es el equivalente de «Row Level Security» en PostgreSQL y SQL Server.
- **Cifrado en tránsito:** Oracle Net ofrece Native Network Encryption (en 23ai/26ai solo con algoritmos fuertes como AES y SHA-2) y TLS. Oracle recomienda TLS porque además autentica al servidor con certificados. El ejemplo `pg_hba.conf` del enunciado corresponde a PostgreSQL; en Oracle la configuración equivalente está en `sqlnet.ora` y `listener.ora`.

Prevención de fuga de datos (DLP) y respaldos cifrados

DLP combina prevención y detección para evitar que la información salga de su ámbito autorizado. A nivel de base de datos, el DBA contribuye con varias medidas:

- cifrado de datafiles y exportaciones;
- control del directorio de exportación;
- auditoría de lecturas masivas y del uso de privilegios amplios;
- copias de desarrollo sin datos reales.

Los **respaldos** son copias completas de la información y requieren la misma protección que la base: deben cifrarse (RMAN con cifrado; Data Pump con `ENCRYPTION=ALL` en las ediciones que lo permiten), y el keystore debe respaldarse y guardarse separado de los datos. El laboratorio mostró dos detalles importantes. Primero, un export de Data Pump guarda en claro los datos de tablas cifradas con TDE (Oracle lo advierte con ORA-39173). Segundo, en Oracle Free el cifrado de exports no está habilitado (ORA-00439), mientras que el de RMAN sí (`V$OPTION`: Backup Encryption = TRUE). Al eliminar un respaldo cifrado, destruir la clave equivale a destruir el dato (*crypto-shredding*). Es más fiable que sobrescribir el archivo en discos SSD.

Registro, monitoreo y correlación (SIEM)

La auditoría responde quién hizo qué, cuándo, desde dónde y con qué resultado. Desde 12c, Oracle ofrece la **auditoría unificada** (`UNIFIED_AUDIT_TRAIL`, almacenada en `AUDSYS.AUD$UNIFIED`). La auditoría tradicional (`SYS.AUD$`, parámetro `AUDIT_TRAIL`) está obsoleta desde 21c y fue retirada en 23ai/26ai. Fine-Grained Auditing registra el acceso a columnas concretas, como la tarjeta. Los **redo logs, los archived logs y LogMiner** registran *cambios* (INSERT, UPDATE, DELETE, DDL) y sirven para reconstruir modificaciones o investigar fraudes. Sin embargo, no registran consultas `SELECT`, que son el principal riesgo para la confidencialidad, por lo que no sustituyen a la auditoría. Un **SIEM** centraliza y correlaciona los registros de varias fuentes, y conserva una copia fuera del alcance del DBA. En el laboratorio no hay un SIEM real: se configuró la retención y la purga controlada del rastro, y el envío por syslog queda propuesto.

Normativa costarricense: Ley 8968 y su reglamento

La Ley n.º 8968, *Protección de la Persona frente al Tratamiento de sus Datos Personales* (7 de julio de 2011), garantiza el derecho a la autodeterminación informativa y se aplica a los datos personales en bases de datos automatizadas o manuales, públicas o privadas (arts. 1 y 2). Distingue datos de acceso irrestricto, de acceso restringido y

sensibles (arts. 3 y 9). Para el DBA, los artículos clave son dos:

- El **artículo 10 (Seguridad de los datos)** obliga al responsable a «adoptar las medidas de índole técnica y de organización necesarias para garantizar la seguridad de los datos de carácter personal y evitar su alteración, destrucción accidental o ilícita, pérdida, tratamiento o acceso no autorizado».
- El **artículo 11 (Deber de confidencialidad)** extiende el secreto profesional o funcional a quienes intervienen en cualquier fase del tratamiento, «aun después de finalizada su relación con la base de datos».

La autoridad de control es la Agencia de Protección de Datos de los Habitantes (Prodhab). El reglamento de la ley es el Decreto Ejecutivo n.º 37554-JP (2013). Los controles de este trabajo son medidas técnicas que contribuyen al artículo 10, pero no constituyen por sí mismos el cumplimiento de la ley, que también exige consentimiento, derechos de acceso y rectificación, e inscripción cuando corresponda.

11. Uso de IA

Herramienta IA	Prompt exacto utilizado	Aporte de la IA	Validación / Corrección del estudiante	Fuente verificada
Claude Code (Claude Opus 5.5, Anthropic)	01 · Texto completo en `docs/ia/prompt-01-analisis-inicial.md` (especificación del proyecto: PHVA, riesgos R-CONF, 15 controles, matriz, pruebas, restricciones de seguridad y de citación)	Lectura del enunciado y las pizarras; transcripción con dudas marcadas; diagnóstico del equipo (solo lectura); verificación de las funciones de Oracle por edición; plan PHVA.	Pendiente	Pendiente
Claude Code (Claude Opus 5.5)	02 · «1. -si es mi laptop, -si,-es individual y mañana necesito llevar un base para enseñarle al profesor y explicarle algo mas o menos 2. tu no puedes descargar oracle?, no te sirve el de docker que tengo ?» (respuestas a la consulta: «usa la que tu creas que es mejor» y «Detenerlo (Recomendado)»)	Elección de Oracle AI Database 26ai Free; creación del contenedor aislado `iso27001-oracle`; diagnóstico E-00; borrador de avance (escala, riesgos, tareas, mapeo ISO).	Pendiente	Oracle AI Database Licensing Information User Manual 26ai (pendiente de revisión)
Claude Code (Claude Opus 5.5)	03 · «entonces del proyecto en si no haz hecho nada? segundo mi nombre es ismael rojas herrera para que lo agregues, tercero, dame un md explicando un poco el proyecto en general, lo que voy a hacer para desarrollarlo y TODO el avance»	Nombre agregado; documento explicativo del avance.	Pendiente	—
Claude Code (Claude Opus 5.5)	04 · «ok, empeza con todo el proyecto, pero separame muy bien en una carpeta lo del avance por APARTE, el md explicativo corrigelo la explicacion damela como si yo la fuera a leer y es exactamente lo que le tengo que decir al profesor por si me pregunta»	Laboratorio completo (10 scripts de configuración), 15 verificaciones, 19 pruebas, 3 scripts de la fase Actuar, ejecución con evidencias, marco teórico, README, artefacto, informe, guion y checklist; carpeta `avance-profesor/` separada.	Pendiente	Ley 8968 (texto de SCIJ/MICITT, arts. 1-3, 9-11); documentación de Oracle 21c/26ai (pendiente de revisión)
Claude Code (Claude Opus 5.5)	05 · «como lo subiste al git si no existe repositorio ? no puedes hacer tu el repositorio sin marca de agua ?» (respuestas a la consulta: «Privado (Recomendado)» y «No incluirlos (Recomendado)»)	Creación del repositorio privado `ismaaa1x/iso27001-confidencialidad-oracle` en GitHub con la cuenta del estudiante; primer commit sin línea de coautoría; exclusión de `.secrets/`, del PDF de la asignación y de las fotos de la pizarra; `.gitattributes` para los finales de línea; revisión de que ninguna contraseña quedara en los archivos subidos.	Pendiente	—

Herramienta IA	Prompt exacto utilizado	Aporte de la IA	Validación / Corrección del estudiante	Fuente verificada
Claude Code (Claude Opus 5.5)	06 · «acuerdate que eso de la declaracion de la ia hay que hacerlo como el profesor lo puso en el pdf que te pase»	Ajuste de esta tabla al formato de la sección 8 (5 columnas y declaración jurada inmediatamente debajo); documento aparte para firmar.	Pendiente	Enunciado del curso, sección 8
Claude Code (Claude Opus 5.5)	07 · «eso del uso de ia te dije que cambiaras mis respuestas osea prompts para que sean mas profesionales y enfocadas en un uso de la herramienta ia, se ve muy poco profesional, el unico prompt que dejas es el que te mande largo, despues en el md que me diste con la explicacion del avance, corrijelo y pon tal y como yo lo voy a decir, osea que yo voy a leer eso para explicarle al profesor, que salga lo que voy a hacer de proyecto, como lo voy a hacer y lo que llevo hasta el momento»	Reescritura de `avance-profesor/EXPLICACION-PARA-EL-PROFESOR.md` como guion de lectura (qué es el proyecto, cómo se hará, avance). Los prompts registrados no se modificaron, porque el enunciado exige el prompt exacto.	Pendiente	—
Claude Code (Claude Opus 5.5)	08 · «ok, haz el recorte y la guía»	Se dejaron en la tabla solo los prompts que generaron contenido del trabajo; guía de validación por fila (sección «Guía para completar la validación»).	Pendiente	Enunciado del curso, sección 8
Claude Code (Claude Opus 5.5)	09 · «bro por que en el pdf y el html del avance escribiste las preguntas al profesor ? ese no es el documento de confidencialidad ?»	Se quitó la sección de consultas al profesor del HTML y del PDF del avance.	Pendiente	—
Claude Code (Claude Opus 5.5)	10 · «si, sacalo del repositorio»	Las notas personales para la reunión dejaron de publicarse en el repositorio (`.gitignore`).	Pendiente	—
Claude Code (Claude Opus 5.5)	11 · «si, pon los accesos directos en la carpeta del avance»	Accesos directos locales al artefacto y al informe, y archivo `.bat` para iniciar el contenedor.	Pendiente	—
Claude Code (Claude Opus 5.5)	12 · «y digamos si tuvieras que explicar el artefacto completo que me pusiste en evidencias como lo harias, dame una explicacion para yo leerla»	Guion personal para explicar el artefacto (`avance-profesor/EXPLICACION-ARTEFACTO.md` , no publicado).	Pendiente	—
Claude Code (Claude Opus 5.5)	13 · «y dame ese html mejor visualmente como si fuera un sistea completo pero solo el front»	Rediseño del artefacto: menú lateral por fases PHVA, panel general con indicadores, mapa de calor de riesgos, madurez por control, hallazgos y módulo de evidencias con visor.	Pendiente	—

Herramienta IA	Prompt exacto utilizado	Aporte de la IA	Validación / Corrección del estudiante	Fuente verificada
Claude Code (Claude Opus 5.5)	14 · «y borra del html la parte de la ia eso lo hacemos despues»	Se quitó la sección de uso de IA del artefacto; se mantiene en el informe y en esta tabla.	Pendiente	—
Claude Code (Claude Opus 5.5)	15 · «no puedes correr los scrips y que se vea en mi coomputadora ?»	Script de demostración en vivo `herramientas/demo.sh` (8 pasos que no modifican el laboratorio ni las evidencias) y acceso directo local.	Pendiente	—
Claude Code (Claude Opus 5.5)	16 · «okey bro no he hecho nada desde la ultima vez, necesito que me pongas en una carpeta aparte, por ejemplo todo lo que llevamos para entregar o avanzado en una carpeta llamada chatgpt»	Carpeta local `chatgpt/` con una copia ordenada de todo lo avanzado y un índice (`00-LEEME.md`).	Pendiente	—
Claude Code (Claude Opus 5.5)	17 · Texto completo en `docs/ia/prompt-17-seguimiento-historico.md` (seguimiento histórico de controles a partir de las fotos de la pizarra del 28/10/2026), más la línea «y dime despues de hacer esos cambios que es lo que tengo que hacer yo que no puedas hacer tu y falte para la entrega paso a paso»	Módulo «Matriz y seguimiento» del artefacto: registro de evaluaciones con revisiones, semáforo, gráfica de evolución por fechas, historial, indicadores, exportación e importación JSON, evaluaciones base recuperadas de las evidencias y datos de demostración separados; pruebas automatizadas en el navegador; documentación (`docs/seguimiento-evaluaciones.md`).	Pendiente	Fotos de la pizarra del 28/10/2026; enunciado del curso (escala 0–4, matriz)
Claude Code (Claude Opus 5.5)	18 · «veo que hay muchas carpetas sueltas en este proyecto, muchas versiones, puedes borrar lo que ests sobre guardado y dejar lo mas reciente limpio» (respuestas a la consulta: «Borrar ambas (Recomendado)» y «Sí, en material-del-curso/ (Recomendado)»)	Inventario del proyecto; se eliminaron la copia `chatgpt/` , `chatgpt.zip` (desactualizado), `corrida.log` y la caché de Python; el enunciado y las fotos de la pizarra se ordenaron en `material-del-curso/` .	Pendiente	—

El prompt 01 completo está en `docs/ia/prompt-01-analisis-inicial.md` .

Declaración Jurada:

Yo, **Ismael Rojas Herrera**, declaro que todo contenido generado con IA ha sido declarado en la tabla anterior, validado contra fuentes oficiales (ISO, documentación del motor de BD) y que asumo responsabilidad por su veracidad. Entiendo que omitir esta declaración constituye falta grave.

Firma: _____ Carné: _____ Fecha: _____

12. Referencias

1. Asamblea Legislativa de la República de Costa Rica. (2011). *Ley n.º 8968: Protección de la persona frente al tratamiento de sus datos personales*. Sistema Costarricense de Información Jurídica. https://pgrweb.go.cr/scij/Busqueda/Normativa/Normas/nrm_texto_completo.aspx?param1=NRTC&nValor1=1&nValor2=70975&nValor3=85989&strTipM=TC
2. Hall, T. (2025, 15 de octubre). *Oracle AI Database 26ai released*. ORACLE-BASE. https://oracle-base.com/blog/2025/10/15/oracle-ai-database-26ai-released/
3. International Organization for Standardization & International Electrotechnical Commission. (2022a). *Information security, cybersecurity and privacy protection — Information security management systems — Requirements* (ISO/IEC Standard No. 27001:2022). https://www.iso.org/standard/27001 [Texto completo no consultado: norma de pago]
4. International Organization for Standardization & International Electrotechnical Commission. (2022b). *Information security, cybersecurity and privacy protection — Information security controls* (ISO/IEC Standard No. 27002:2022). https://www.iso.org/standard/75652.html [Texto completo no consultado: norma de pago]
5. Open Security Architecture. (s. f.). *ISO/IEC 27002:2022* [Fuente secundaria para los títulos de los controles]. https://www.opensecurityarchitecture.org/frameworks/iso-27002-2022
6. Oracle. (s. f.-a). *Database licensing information user manual 21c*. https://docs.oracle.com/en/database/oracle/oracle-database/21/dblic/Licensing-Information.html
7. Oracle. (s. f.-b). *Database Express Edition installation guide 21c for Linux x86-64: Licensing restrictions*. https://docs.oracle.com/en/database/oracle/oracle-database/21/xeinl/licensing-restrictions.html
8. Oracle. (s. f.-c). *Database security guide 21c: Introduction to auditing*. https://docs.oracle.com/en/database/oracle/oracle-database/21/dbseg/introduction-to-auditing.html
9. Oracle. (s. f.-d). *Oracle AI Database 26ai: Changes, desupports, and deprecations*. https://docs.oracle.com/en/database/oracle/oracle-database/26/upgrd/oracle-database-changes-deprecations-desupports.html
10. Oracle. (s. f.-e). *Oracle AI Database security guide 26ai: Securing data for Oracle AI Database connections*. https://docs.oracle.com/en/database/oracle/oracle-database/26/dbseg/nne-vs-tls.html
11. Oracle. (2026). *Oracle AI Database licensing information user manual 26ai*. https://docs.oracle.com/en/database/oracle/oracle-database/26/dblic/Licensing-Information.html
12. Poder Ejecutivo de la República de Costa Rica. (2013). *Decreto Ejecutivo n.º 37554-JP: Reglamento a la Ley de Protección de la Persona frente al Tratamiento de sus Datos Personales*. Sistema Costarricense de Información Jurídica. https://pgrweb.go.cr/scij/Busqueda/Normativa/Normas/nrm_texto_completo.aspx?param1=NRTC&nValor1=1&nValor2=74352&nValor3=106487&strTipM=TC
13. Rose, S., Borchert, O., Mitchell, S., & Connelly, S. (2020). *Zero trust architecture* (NIST Special Publication 800-207). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-207